

SWISSPERIENCES

Security Audit Report

Prepared for Pascal Broennimann | March 2026

BEFORE AUDIT	AFTER FIXES	AFTER ROTATION
C 58/100	A- 88/100	A 92/100

Introduction

This document summarizes a full security review conducted on the Swissperiences platform — the technology that powers the membership website, payments, email notifications, and member database.

The goal was to identify vulnerabilities, fix them, and ensure the platform is safe for members and partners. The review covered all layers: website code, server, database, email systems, and Stripe payment processing.

What We Checked

A security audit looks for ways a malicious actor could exploit weaknesses. We checked 10 categories:

- 1 Hardcoded secrets — API keys or passwords written directly in code
- 2 Database access controls — who can read or write what
- 3 API route security — server endpoints open to abuse
- 4 Payment webhook integrity — verifying Stripe payment signals
- 5 Cross-site scripting (XSS) — malicious code injection via forms
- 6 Known software vulnerabilities — outdated libraries with public CVEs
- 7 Environment variable security — secrets accidentally visible in the browser
- 8 CORS configuration — which websites can communicate with the server
- 9 Authentication flow — login security and session token handling
- 10 Edge function security — internal serverless functions (Supabase)

Severity Levels

CRITICAL	Needs immediate attention. Exploitation could cause real damage.
WARNING	Should be fixed soon. Lower risk, but a real concern.
INFO	Good to know. Low risk, best-practice improvement.

CRITICAL Issues Found — 3

C-1 — Secret Key Exposed in Code Repository

What it was: A private authentication key was written directly into a database config file stored in Git. Git keeps full history — this key was visible to anyone with repository access, indefinitely.

Why it matters: This key acts like a service password for internal functions. An attacker could impersonate the system and send emails on behalf of Swissperiences.

What was done: Key removed from active code. Platform migrated to Supabase's new JWT Signing Key system (asymmetric ECC — industry standard). Key rotation in progress to fully invalidate the old key.

Status: Resolved — key rotation in progress

C-2 — Malicious Code Injection via Partnership Form (XSS)

What it was: The partnership form inserted user input directly into HTML emails without sanitizing — a Cross-Site Scripting (XSS) vulnerability.

Why it matters: A malicious actor could inject code that executes when the admin reads the email — stealing sessions, redirecting to phishing pages, taking browser actions.

What was done: All user inputs are now sanitized before use. Special characters are escaped, preventing code injection entirely.

Status: Resolved

C-3 — Internal Error Details Exposed to Users

What it was: When server errors occurred, raw technical messages were returned to the user's browser — including internal service names, error codes, and stack traces.

Why it matters: Internal error messages reveal how the system is built and may hint at exploitable weaknesses — valuable intelligence for attackers.

What was done: All error responses now return generic messages only. Detailed errors are logged server-side, accessible only to the development team.

Status: Resolved

WARNING Issues Found — 6

W-1 — CORS Open to All Websites

What it was: Some API routes had CORS set to wildcard (*) — any website on the internet could make requests to those endpoints.

What was done: CORS tightened to only allow requests from swissperiences.ch and www.swissperiences.ch.

Status: Resolved

W-2 — Rate Limiting Bug

What it was: Rate limiting had a subtle bug in how the request counter was tracked — abusive requests could slip through.

What was done: Logic corrected to properly count and block abusive requests.

Status: Resolved

W-3 — API Routes Database Permissions

What was checked: Whether server API routes used the correct elevated permission level when writing to the database.

What was found: Routes were already correctly using service-role keys. No change needed.

Status: Already correct

W-5 — Authentication Token Algorithm — Outdated

What it was: The notify-application function validated tokens only with old HS256 algorithm. After migrating to ECC (ES256), it would have stopped working.

What was done: Function now supports both HS256 (backward compat) and ES256 (new keys). Deployed to production.

Status: Resolved

W-7 — Admin Email List Hardcoded in Database

What was checked: Whether admin email addresses were hardcoded or stored dynamically in the database.

What was found: Already resolved in a prior update — stored in a dedicated database table. No change needed.

Status: Already correct

W-8 — Outdated Dependencies with Known Vulnerabilities

What it was: 10 publicly known vulnerabilities in project libraries: path-to-regexp (denial-of-service), undici (request smuggling, memory exhaustion), minimatch (denial-of-service).

What was done: Upgraded Vite (v5 to v8) and @vercel/node (v3 to v4). Build verified. 7 residual low-risk vulnerabilities remain in build-time tools only — no runtime risk.

Status: Resolved

W-9 — Internal Error Messages Leaked in API Responses

What it was: Several API routes returned raw error messages from third-party services (Resend, Stripe) verbatim — exposing internal details to network monitoring.

What was done: All affected routes updated to return generic messages. Error details in server logs only.

Status: Resolved

What Still Needs To Be Done

1. Complete JWT Key Rotation — HIGH PRIORITY

What: The new JWT Signing Key system is migrated and the function updated. Final step: click "Rotate signing key" in the Supabase dashboard. This permanently invalidates the old exposed key.

Why: Until rotation is complete, the old exposed key still technically works.

Risk: Zero downtime. The platform will continue working normally.

2. React Router Open Redirect (C-4) — LOW PRIORITY

What: A known CVE in React Router allows crafting a link that redirects users to an external site. Requires attacker to send a malicious link that a user clicks.

Why low priority: Small, vetted member base means practical risk is very low. Fix may introduce breaking changes — address in a planned sprint.

Summary Table

#	Issue	Severity	Status
C-1	Secret key in code repository	CRITICAL	Resolved (rotation in progress)
C-2	XSS in partnership form	CRITICAL	Resolved
C-3	Error details exposed	CRITICAL	Resolved
W-1	CORS open to all	WARNING	Resolved
W-2	Rate limiting bug	WARNING	Resolved
W-3	Database permissions	WARNING	Already correct
W-5	JWT algorithm outdated	WARNING	Resolved
W-7	Hardcoded admin emails	WARNING	Already correct
W-8	Vulnerable dependencies	WARNING	Resolved
W-9	Error messages leaked	WARNING	Resolved

C-4	React Router XSS	CRITICAL	Pending (low risk)
—	JWT Key Rotation	—	In Progress

SWISSPERIENCES

Rapport d'Audit de Sécurité

Prepares pour Pascal Broennimann | Mars 2026

AVANT L'AUDIT	APRES CORRECTIONS	APRES ROTATION
C 58/100	A- 88/100	A 92/100

Introduction

Ce document resume un audit de securite complet mene sur la plateforme Swissperiences — la technologie qui alimente le site web d'adhesion, les paiements, les notifications par e-mail et la base de donnees des membres.

L'objectif etait d'identifier les vulnerabilites, de les corriger et de s'assurer que la plateforme est securisee pour les membres et les partenaires. L'examen a couvert toutes les couches : code du site web, serveur, base de donnees, systemes d'e-mail et traitement des paiements Stripe.

Ce que nous avons verifie

Un audit de securite cherche les facons dont un acteur malveillant pourrait exploiter des faiblesses. Nous avons verifie 10 categories :

- 1 Secrets codes en dur — cles API ou mots de passe ecrits directement dans le code
- 2 Controles d'acces a la base de donnees — qui peut lire ou ecrire quoi
- 3 Securite des routes API — points de terminaison serveur ouverts aux abus
- 4 Integrite des paiements Stripe — verification des signaux de paiement
- 5 Scripts intersites (XSS) — injection de code malveillant via des formulaires
- 6 Vulnerabilites logicielles connues — bibliotheques obsoletes avec CVE publics
- 7 Securite des variables d'environnement — secrets visibles dans le navigateur
- 8 Configuration CORS — quels sites web peuvent communiquer avec le serveur
- 9 Flux d'authentification — securite de connexion et gestion des sessions
- 10 Securite des fonctions Edge — fonctions serverless internes (Supabase)

Niveaux de gravite

CRITIQUE	Necessite une attention immediate. L'exploitation pourrait causer de vrais dommages.
AVERTISSEMENT	Doit etre corrige rapidement. Risque plus faible, mais preoccupation réelle.
INFO	Bon a savoir. Faible risque, amelioration des meilleures pratiques.

Problemes CRITIQUES trouves — 3

C-1 — Cle secrete exposee dans le depot de code

Ce que c'était : Une cle d'authentification privee etait ecrite directement dans un fichier de configuration stocke dans Git. Git conserve un historique complet — cette cle etait visible par quiconque ayant acces au depot, indefiniment.

Pourquoi c'est important : Cette cle agit comme un mot de passe de service pour des fonctions internes. Un attaquant aurait pu se faire passer pour le systeme et envoyer des e-mails au nom de Swissperiences.

Ce qui a ete fait : Cle retiree du code actif. Plateforme migree vers le nouveau systeme JWT Signing Keys de Supabase (ECC asymetrique — standard industriel). Rotation de cle en cours pour invalider definitivement l'ancienne cle.

Status: Resolu — rotation en cours

C-2 — Injection de code malveillant via formulaire (XSS)

Ce que c'était : Le formulaire de partenariat inserait les saisies utilisateur directement dans des e-mails HTML sans les assainir — une vulnerabilite XSS.

Pourquoi c'est important : Un acteur malveillant pourrait injecter du code qui s'execute lorsque l'admin lit l'e-mail — vol de session, redirection vers des pages de phishing, actions dans le navigateur.

Ce qui a ete fait : Toutes les saisies utilisateur sont desormais assainies avant utilisation. Les caracteres speciaux sont echappes, empechant completement l'injection de code.

Status: Resolu

C-3 — Details d'erreurs internes exposes aux utilisateurs

Ce que c'était : Lors d'erreurs serveur, les messages techniques bruts etaient renvoyes au navigateur — incluant des noms de services internes, des codes d'erreur et des traces techniques.

Pourquoi c'est important : Ces informations revelent la structure du systeme et peuvent indiquer des faiblesses exploitables — precieux pour les attaquants.

Ce qui a ete fait : Toutes les reponses d'erreur renvoient desormais des messages generiques. Les details sont enregistres uniquement cote serveur.

Status: Resolu

Problemes d'AVERTISSEMENT trouves — 6

W-1 — CORS ouvert a tous les sites web

Ce que c'etait : Certaines routes API avaient CORS configure en mode generique (*) — n'importe quel site web pouvait faire des requetes a ces points de terminaison.

Ce qui a ete fait : CORS resserre pour n'autoriser que les requetes de swissperiences.ch et www.swissperiences.ch.

Status: Resolu

W-2 — Bug de limitation de debit

Ce que c'etait : La limitation de debit avait un bug subtil dans le suivi du compteur — des requetes abusives pouvaient passer.

Ce qui a ete fait : Logique corrige pour compter et bloquer correctement les requetes abusives.

Status: Resolu

W-3 — Permissions de base de donnees dans les routes API

Ce qui a ete verifie : Si les routes API utilisaient le niveau de permission correct lors de l'ecriture en base de donnees.

Ce qui a ete trouve : Les routes utilisaient deja correctement des cles a role de service. Aucun changement necessaire.

Status: Deja correct

W-5 — Algorithme de validation des jetons — obsolete

Ce que c'etait : La fonction notify-application validait les jetons uniquement avec l'ancien algorithme HS256. Apres migration vers ECC (ES256), elle aurait cesse de fonctionner.

Ce qui a ete fait : La fonction supporte desormais les deux algorithmes simultanement. Deployee en production.

Status: Resolu

W-7 — Liste d'e-mails admin codee en dur

Ce qui a ete verifie : Si les adresses e-mail des administrateurs etaient codees en dur ou stockees dynamiquement.

Ce qui a ete trouve : Deja resolu dans une mise a jour anterieure. Aucun changement necessaire.

Status: Deja correct

W-8 — Dependances obsoletes avec vulnerabilites connues

Ce que c'était : 10 vulnerabilites connues dans des bibliotheques du projet : path-to-regexp (deni de service), undici (contrebande de requetes, epuisement memoire), minimatch (deni de service).

Ce qui a ete fait : Mise a niveau de Vite (v5 vers v8) et @vercel/node (v3 vers v4). Build verifie. 7 vulnerabilites residuelles de faible risque dans les outils de build uniquement — aucun risque d'execution.

Status: Resolu

W-9 — Messages d'erreur internes divulgues

Ce que c'était : Plusieurs routes API renvoyaient des messages d'erreur bruts de services tiers (Resend, Stripe) — exposant des details d'implementation.

Ce qui a ete fait : Toutes les routes mises a jour pour renvoyer des messages generiques. Details dans les journaux serveur uniquement.

Status: Resolu

Ce qui doit encore etre fait

1. Completer la rotation de la cle JWT — HAUTE PRIORITE

Quoi : Le nouveau systeme JWT a ete migre et la fonction mise a jour. Etape finale : cliquer sur "Rotate signing key" dans le tableau de bord Supabase. Cela invalide definitivement l'ancienne cle exposee.

Pourquoi : Jusqu'a la rotation, l'ancienne cle exposee fonctionne techniquement encore.

Risque : Zero. Aucune interruption de service. La plateforme continue de fonctionner normalement.

2. React Router Open Redirect (C-4) — FAIBLE PRIORITE

Quoi : Une CVE connue dans React Router permet de creer un lien qui redirige vers un site externe. Necessite que l'attaquant envoie un lien malveillant qu'un utilisateur clique.

Pourquoi faible priorite : Petite base de membres verifies = risque pratique tres faible. La correction peut introduire des changements — a traiter lors d'un sprint planifie.

Tableau recapitulatif

#	Probleme	Gravite	Statut
C-1	Cle secrete dans le depot	CRITIQUE	Resolu (rotation en cours)
C-2	XSS dans le formulaire	CRITIQUE	Resolu
C-3	Details d'erreur exposes	CRITIQUE	Resolu
W-1	CORS ouvert a tous	AVERT.	Resolu

W-2	Bug limitation de debit	AVERT.	Resolu
W-3	Permissions base de donnees	AVERT.	Deja correct
W-5	Algorithme JWT obsolete	AVERT.	Resolu
W-7	E-mails admin codes en dur	AVERT.	Deja correct
W-8	Dependances vulnerables	AVERT.	Resolu
W-9	Messages d'erreur divulgues	AVERT.	Resolu
C-4	XSS React Router	CRITIQUE	En attente (faible risque)
—	Rotation cle JWT	—	En cours